

Integración de pagos con Azul y CardNET

Guía secuencial para activar tarjetas de crédito, débito y links de pago con facturación, inventario, correo y control administrativo.

CAPA	ESTADO
Aplicacion y checkout	Preparado
Base de datos y callbacks	Preparado
Activacion bancaria	Requiere credenciales y certificacion

Preparado el 15 de julio de 2026

Versión técnica para certificación y despliegue

1. Estado real de la implementación

La base técnica queda preparada y desactivada por defecto. La activación real requiere credenciales comerciales de cada adquirente, certificación del comercio, acceso autenticado al proyecto Supabase y un dominio de correo verificado.

Componente	Estado	Archivo principal
Esquema, RLS y configuración	Preparado	supabase/migrations/20260715090000_hosted_card_payments.sql
Creación de pagos alojados	Preparado	supabase/functions/create-hosted-payment/index.ts
Validación de retornos	Preparado	supabase/functions/card-payment-callback/index.ts
Diagnóstico Admin	Preparado	supabase/functions/payment-provider-health/index.ts
Liquidación, stock y factura	Atómica e idempotente	supabase/functions/_shared/order-payment-settlement.ts
Checkout responsive	Preparado	src/pages/TransferCheckout.tsx
Administración	Preparado	src/pages/admin/AdminPaymentMethods.tsx
Factura imprimible/PDF	Preparado	src/pages/InvoiceDetail.tsx
Correo transaccional	Preparado	supabase/functions/send-order-email/index.ts

2. Decisión de seguridad

La aplicación usa las páginas de pago alojadas de Azul y CardNET. El usuario introduce número de tarjeta, vencimiento y CVV directamente en la pasarela. La aplicación no solicita, procesa, registra ni almacena esos datos.

- Azul: el servidor firma el formulario con HMAC SHA-512 y valida el `AuthHash` del retorno antes de confirmar la orden.
- CardNET: el servidor crea una sesión temporal, conserva el `session-key` en una tabla privada y consulta el resultado desde servidor antes de confirmar.
- Doble retorno: la liquidación bloquea la orden y ejecuta pago, descuento, inventario y factura dentro de una transacción de base de datos.
- Secretos: se guardan como secretos de Supabase Edge Functions. Nunca deben usar prefijo `VITE_`.

3. Lo que debe solicitar el cliente/comercio

3.1 Azul

Solicitar a Azul una afiliación de comercio electrónico con Página de Pagos y 3DS. Pedir por separado los valores de pruebas y producción:

1. `MerchantId`.
2. `MerchantName` aprobado.
3. `MerchantType`.
4. `CurrencyCode` asociado al MID.
5. `AuthKey` de autenticación.
6. Casos y tarjetas de certificación.
7. Confirmación de las URLs principal y de contingencia de producción.

8. Confirmación del dominio de retorno permitido:

<https://xuhvlomytegdibifziilf.supabase.co/functions/v1/card-payment-callback>.

La documentación oficial indica que el navegador del cliente debe enviar el POST a la Página de Pago, que los ambientes usan URLs distintas y que la respuesta debe validarse con su hash.

3.2 CardNET

Solicitar afiliación al Botón de Pago con pantalla alojada y 3DS. Pedir:

1. `MerchantNumber`.
2. `MerchantTerminal`.
3. `MerchantName` exactamente como lo apruebe CardNET.
4. `MerchantType`.
5. `AcquiringInstitutionCode`.
6. URLs de sesiones y autorización para QA y producción.
7. Datos, casos y tarjetas de certificación 3DS.
8. Registro del dominio de retorno indicado anteriormente.

CardNET requiere crear la sesión desde servidor, enviar únicamente `SESSION` al navegador y consultar luego `sessions/{SESSION}?sk={session-key}`. El código aprobado es `00`.

3.3 Correo y facturación

1. Crear/verificar un dominio en Resend.
2. Crear `RESEND_API_KEY`.
3. Definir un remitente verificado, por ejemplo `Bárbaro Nutrition <pedidos@dominio.com>`.
4. Sustituir las secuencias NCF de ejemplo por rangos reales autorizados por DGII antes de producción.
5. Revisar razón social, RNC, dirección fiscal, tasa ITBIS y tipo de comprobante en Admin.

Los NCF de ejemplo del repositorio no son autorización fiscal. La operación en producción debe usar rangos vigentes emitidos por DGII y revisados por contabilidad.

4. Paso a paso técnico

Paso 1 - Respalidar y revisar migraciones

```
npx supabase@latest login
npx supabase@latest link --project-ref xuhvlomytegdibifziilf
npx supabase@latest migration list
```

Revisar todas las migraciones pendientes antes de ejecutar `db push`, especialmente si producción contiene cambios manuales.

Paso 2 - Aplicar la integración de base de datos

El archivo de integración solicitado es:

`supabase/migrations/20260715090000_hosted_card_payments.sql`

Aplicar las migraciones pendientes:

```
npx supabase@latest db push
```

La migración crea configuración pública controlada por RLS, sesiones privadas, auditoría de retornos y la función transaccional de liquidación. Azul, CardNET y link de pago quedan inactivos.

Paso 3 - Configurar secretos de pruebas

Copiar `supabase/.env.payments.example` a un archivo local que no se suba a Git, completar credenciales de QA y ejecutar:

```
npx supabase@latest secrets set --env-file supabase/.env.payments.local
npx supabase@latest secrets list
```

Secretos mínimos:

```
PUBLIC_SITE_URL
AZUL_MERCHANT_ID
AZUL_MERCHANT_NAME
AZUL_AUTH_KEY
CARDNET_MERCHANT_NUMBER
CARDNET_MERCHANT_TERMINAL
CARDNET_MERCHANT_NAME
RESEND_API_KEY
ORDER_EMAIL_FROM
```

Paso 4 - Desplegar funciones

```
npx supabase@latest functions deploy create-hosted-payment
npx supabase@latest functions deploy card-payment-callback --no-verify-jwt
npx supabase@latest functions deploy payment-provider-health
npx supabase@latest functions deploy send-order-email
```

`card-payment-callback` es público porque las pasarelas no envían un JWT de Supabase. Su autenticidad se verifica dentro de la función mediante firma Azul o consulta privada de sesión CardNET.

Paso 5 - Configurar Admin

1. Iniciar sesión con rol `admin` o `manager`.
2. Abrir Admin > Métodos de pago.
3. Mantener la pasarela en Pruebas / certificación.
4. Pulsar Ejecutar diagnóstico.
5. Corregir cualquier secreto indicado.
6. Activar solo cuando muestre Listo para activar.
7. Confirmar que la opción aparece en `/checkout/transerencia`.

El panel bloquea la activación si el diagnóstico local no está listo. El diagnóstico no sustituye la certificación del banco.

Paso 6 - Link de pago opcional

En Admin puede registrarse una URL HTTPS. Se admiten estas variables:

```
https://proveedor.com/pagar?order={order_id}&amount={amount}&currency={currency}
```

El enlace crea una orden pendiente y redirige al proveedor. Sin un webhook específico del proveedor, la confirmación continúa siendo manual. No debe tratarse como pago automático.

5. Certificación en sandbox

Ejecutar con Azul y CardNET, al menos:

1. Compra aprobada.
2. Compra declinada.
3. Cancelación del usuario.
4. Reto 3DS aprobado.

5. Reto 3DS rechazado o abandonado.
6. Doble clic en retorno/recarga de la página.
7. Monto con centavos.
8. Orden con descuento.
9. Orden con comprobante fiscal.
10. Vista móvil de checkout, retorno y factura.

Para una compra aprobada verificar:

- `orders.status = paid.`
- `order_payments.status = verified.`
- `payment_return_events.verified = true.`
- El inventario disminuye una sola vez.
- Existe una sola factura para la orden.
- El cliente ve el botón Descargar factura.
- El correo de pago confirmado llega al destinatario.

Para rechazo o cancelación verificar que la orden no se marque pagada, no se emita factura y no se descuenta inventario.

6. Paso a producción

1. Obtener aprobación escrita de certificación.
2. Crear una copia de seguridad de base de datos.
3. Sustituir secretos QA por secretos de producción.
4. Confirmar `PUBLIC_SITE_URL` con el dominio HTTPS definitivo.
5. En Admin cambiar la pasarela a Producción.
6. Ejecutar nuevamente el diagnóstico.
7. Activar una sola pasarela primero.
8. Realizar una compra real de importe pequeño.
9. Verificar conciliación en el portal del adquirente, orden, factura, inventario y correo.
10. Activar la segunda pasarela después de completar la observación inicial.

7. Operación diaria en Admin

- Revisar órdenes pendientes o rechazadas.
- Consultar referencias del adquirente sin almacenar tarjeta.
- Revisar `payment_return_events` cuando una orden no coincida con el portal.
- Descargar facturas desde Admin > Facturas.
- Conciliar total, autorización/RRN, fecha y estado con Azul o CardNET.
- No copiar números de tarjeta a notas, tickets, logs o correos.

8. Correo y dominio

El remitente de prueba `onboarding@resend.dev` tiene restricciones. Para producción:

1. Verificar el dominio en Resend con sus registros DNS.
2. Configurar `ORDER_EMAIL_FROM` con ese dominio.
3. Enviar un correo de prueba a una cuenta externa.
4. Revisar SPF, DKIM y DMARC.
5. Probar correo en Gmail, Outlook y móvil.

El endpoint de correo valida que la solicitud provenga del dueño de la orden, personal autorizado o service role.

9. Seguridad y cumplimiento

- Todo el tráfico de producción debe usar HTTPS/TLS.
- No guardar PAN, CVV, vencimiento, token de bóveda ni `session-key` en logs públicos.
- Rotar `AuthKey` y credenciales si se exponen.
- Limitar acceso a secretos y tablas de auditoría.
- Mantener RLS habilitado.
- Revisar contracargos, reembolsos y conciliación según los procedimientos del adquirente.
- Completar el cuestionario PCI que corresponda con el adquirente; el uso de página alojada reduce alcance, pero no elimina obligaciones del comercio.

10. Solución de problemas

Síntoma	Revisión
No aparece Azul/CardNET	Migración aplicada, <code>is_active</code> , diagnóstico y rol Admin
Azul rechaza el formulario	Merchant, moneda, URLs exactas y <code>AZUL_AUTH_KEY</code> del mismo ambiente
Azul vuelve pero no paga	<code>AuthHash</code> , <code>IsoCode</code> , monto y <code>OrderNumber</code>
CardNET no crea sesión	número, terminal, nombre aprobado, URL de sesiones y datos 3DS
CardNET vuelve pendiente	vigencia de 30 minutos, <code>SESSION</code> , <code>session-key</code> y código 00
No se crea factura	evento verificado, secuencia de factura, factura existente y logs de callback
No llega correo	<code>RESEND_API_KEY</code> , dominio/remitente, destinatario y logs de <code>send-order-email</code>
Error 401/403 en Admin	sesión vigente y rol <code>admin/manager</code> en <code>user_roles</code>

11. Reversión segura

Ante un incidente:

1. Desactivar la pasarela en Admin; no es necesario retirar el sitio.
2. Mantener transferencia disponible.
3. No borrar órdenes, pagos ni eventos de auditoría.
4. Conciliar pagos aprobados directamente en el portal del adquirente.

5. Corregir, volver a sandbox, certificar y reactivar.

12. Referencias oficiales

- [Azul - Comercio Online](#)
- [Azul - Portal de desarrolladores](#)
- [Azul - Manual Página de Pagos](#)
- [CardNET - Integración con pantalla POST](#)
- [Supabase - Seguridad de Edge Functions](#)
- [Supabase - Secretos de Edge Functions](#)
- [Resend - Verificación de dominios](#)

13. Límite de la validación realizada

El código puede validarse localmente con TypeScript, build, pruebas unitarias y navegación del sitio. Una transacción bancaria real no puede declararse certificada sin credenciales QA/producción, tarjetas de prueba oficiales, aprobación del adquirente y acceso autenticado para desplegar en Supabase. La activación permanece bloqueada por defecto hasta completar esos pasos.